Your logo

My Company
United States

Security & GRC Scorecard

Assessment 2026-10-30 · 10/30/2026 19:35:30 · Odoo 18.0-20261015 Community

F	17/100	4%
Grade	Security score	GRC compliance

Money at risk (open cases)

$ 54,800.00

5 case(s) to review (15 alerts)

Paid by users holding toxic rights (12 months)

$ 53,250.00

2 user(s) with conflicting rights

Cases to review

Severity	Incident	Why	At risk
Critical	**Globex Freight · DE44500105175407324931** by admin, ana.ap	Bank account changed before payment, Bank account changed without an audit trail, Bank account shared between unrelated contacts, Bank account trusted by the person who changed it	**$ 19,600.00**
Critical	**Acme Industrial Supplies · GB29NWBK60161331926819** by ana.ap	Bank account changed before payment, Bank account shared between unrelated contacts, Bank account trusted by the person who changed it	**$ 18,400.00**
Critical	**N0rthwind Logistics Ltd · DE89370400440532013000** by ana.ap	Bank account changed before payment, New vendor paid within days by the person who created it, Vendor name imitates an existing vendor	**$ 7,300.00**
High	**Northwind Logistics · PBNK1/2026/00003** by ana.ap	Bill paid by the person who entered it	**$ 4,750.00**
Medium	**Northwind Logistics · BILL/2026/10/0002** by ana.ap	Duplicate vendor bill	**$ 4,750.00**

Top 3 fixes

1. **No payments to freshly changed bank accounts** (Critical): 4 payment(s) to recently changed bank accounts to review, touching $ 45,300.00: PBNK1/2026/00002 to Acme Industrial Supplies: account number changed by ana.ap 0 day(s) before payment by ana.ap, PBNK1/2026/00005 to Globex Freight: account number changed by ana.ap 0 day(s) before payment by ana.ap, PBNK1/2026/00004 to Northwind Logistics: account number changed by ana.ap 0 day(s) before payment by ana.ap (+1 more)
   Call the vendor on a number you already had to confirm the new account, record the call in the event's review note, and mark it legitimate.

2. **Bank accounts verified by a second person** (Critical): 3 self-verified bank account(s) to review, touching $ 19,600.00: DE44500105175407324931 of Globex Freight changed and trusted by the same person (ana.ap); 1 payment(s) since, DE44500105175407324931 of Northwind Logistics changed and trusted by the same person (ana.ap); 1 payment(s) since, ES9121000418450200051332 of Acme Industrial Supplies changed and trusted by the same person (ana.ap); 0 payment(s) since
   Have a second person re-verify the account with the vendor and re-trust it.
3. **Bank account changes always leave a trace** (Critical): 2 bank account change(s) hidden from the audit trail to review, touching $ 19,600.00: DE44500105175407324931 of Globex Freight: account number changed to DE44500105175407324931 by ana.ap on 2026-10-30 19:01:38 with the bank account's own audit trail switched off (tracking_disable); 1 payment(s) since, DE44500105175407324931 of Northwind Logistics: account number changed to DE44500105175407324931 by ana.ap on 2026-10-30 18:50:55 with the bank account's own audit trail switched off (tracking_disable); 1 payment(s) since
   Treat as a suspected fraud attempt: freeze payments to the account, verify it with the vendor on a known phone number, and review what else the same user changed through the API.

Framework compliance

Framework	Satisfied	Applicable	Compliance
ISO/IEC 27001:2022 Annex A	0	19	0%
SOC 2 Trust Services Criteria	0	11	0%
CIS Critical Security Controls	2	18	11%

All controls

Status	Severity	Control	Detail
Fail	Critical	No default 'admin' account	The 'admin' account still has the default password 'admin'.
Fail	Critical	Strong, hashed master password	The master password is a common default.
Fail	Critical	Audit trail not erased	3 chatter message(s) were deleted from records that still exist, which is how an audit trail gets erased: admin deleted 'Bank Account #6 [1] updated [1] #' on res.partner,616, admin deleted 'Bank Account #6 [1] created [1] #' on res.partner,616, admin deleted 'Bank Account #6 [1] updated [1] #' on res.partner,616.

Your logo

My Company
United States

Status	Severity	Control	Detail
Fail	Critical	Automated off-site backups	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Critical	No one can redirect and pay alone	2 user(s) can change a vendor's bank account, mark it trusted and pay it alone, which defeats Odoo's bank-account validation safeguard: admin ($ 3,200.00), ana.ap ($ 50,050.00). 2 of them created $ 53,250.00 of payments in the last 12 months.
Fail	Critical	User administrators do not pay	1 user(s) can grant themselves any right, then pay: admin ($ 3,200.00). 1 of them created $ 3,200.00 of payments in the last 12 months.
Fail	Critical	No payments to freshly changed bank accounts	4 payment(s) to recently changed bank accounts to review, touching $ 45,300.00: PBNK1/2026/00002 to Acme Industrial Supplies: account number changed by ana.ap 0 day(s) before payment by ana.ap, PBNK1/2026/00005 to Globex Freight: account number changed by ana.ap 0 day(s) before payment by ana.ap, PBNK1/2026/00004 to Northwind Logistics: account number changed by ana.ap 0 day(s) before payment by ana.ap (+1 more)
Fail	Critical	Bank accounts verified by a second person	3 self-verified bank account(s) to review, touching $ 19,600.00: DE44500105175407324931 of Globex Freight changed and trusted by the same person (ana.ap); 1 payment(s) since, DE44500105175407324931 of Northwind Logistics changed and trusted by the same person (ana.ap); 1 payment(s) since, ES9121000418450200051332 of Acme Industrial Supplies changed and trusted by the same person (ana.ap); 0 payment(s) since
Fail	Critical	Bank account changes always leave a trace	2 bank account change(s) hidden from the audit trail to review, touching $ 19,600.00: DE44500105175407324931 of Globex Freight: account number changed to DE44500105175407324931 by ana.ap on 2026-10-30 19:01:38 with the bank account's own audit trail switched off (tracking_disable); 1 payment(s) since, DE44500105175407324931 of Northwind Logistics: account number changed to DE44500105175407324931 by ana.ap on 2026-10-30 18:50:55 with the bank account's own audit trail switched off (tracking_disable); 1 payment(s) since
Fail	Critical	No bank account shared between unrelated contacts	2 bank account(s) shared between unrelated contacts to review, touching $ 38,000.00: GB29NWBK60161331926819 is or was registered on 2 different contacts: Acme Industrial Supplies, Ana Pereira (private) (created by ana.ap) (some no longer hold it: the number was changed afterwards); 1 payment(s) made to it, DE44500105175407324931 is or was registered on 2 different contacts: Northwind Logistics, Globex Freight; 2 payment(s) made to it
Fail	Critical	No lookalike vendors	1 lookalike vendor(s) to review, touching $ 7,300.00: 'N0rthwind Logistics Ltd' (created by ana.ap on 2026-10-30) imitates existing vendor 'Northwind Logistics'; 1 payment(s) to it
Fail	Critical	New vendors not paid at once by their creator	1 new vendor(s) paid within a week by their creator to review, touching $ 7,300.00: ana.ap created N0rthwind Logistics Ltd and its bank account and paid it 0 day(s) later (PBNK1/2026/00006)
Fail	High	Two-factor authentication in use	3 administrator(s) without 2FA: admin, it.support, it.support2
Fail	High	Two-factor authentication enforced	2FA is optional; users can log in with a password only.
Fail	High	No unexpected new administrators	Privileged access changed: privileged accounts created in the last 30 days: it.support (by admin), it.support2 (by admin).
Fail	High	Brute-force protection on	Login throttling is disabled (base.login_cooldown_after = 0): passwords can be guessed without limit, including through the XML-RPC/JSON-RPC API.

Your logo

My Company
United States

Status	Severity	Control	Detail
Fail	High	Record rules come from reviewed modules	1 record rule(s) on financial/security data were created by hand. Rules decide who can SEE records, so they can hide transactions from reviewers: Payment visibility on account.payment for Technical / Show Accounting Features - Readonly by admin: [('create_uid', '!=', 6)]
Fail	High	No public attachments on business documents	1 attachment(s) on business documents are public: anyone with the URL can download them without logging in (1 on account.move).
Fail	High	Database manager disabled	The database manager and database list are enabled (list_db = True). Anyone holding the master password can download or drop databases.
Fail	High	No unreviewed code stored in the database	1 piece(s) of Python code were added through the database rather than a reviewed module: System cleanup (scheduled action, inactive, by admin on 2026-10-30: sudo(), bank data). Code here runs with full server access and survives module reinstalls.
Fail	High	Strong, least-privilege database credentials	Database credentials are weak: the database password is a common default ('od***'). Odoo connects over the network to host 'db'; anyone who reaches PostgreSQL bypasses every Odoo access rule and audit trail.
Fail	High	No bulk exports of sensitive data	Bulk exports of sensitive data in the last 30 days: ana.ap: 600 res.partner. 2 user(s) hold export rights.
Fail	High	Restore tested in the last 90 days	No attestation recorded. Record evidence under Shield > Attestations.
Fail	High	Quarterly user access review	No attestation recorded. Record evidence under Shield > Attestations.
Fail	High	Bill entry separated from payment	2 user(s) can enter a vendor bill and pay it without a second person: admin ($ 3,200.00), ana.ap ($ 50,050.00). 2 of them created $ 53,250.00 of payments in the last 12 months.
Fail	High	Bills not paid by the person who entered them	1 bill(s) paid by the person who entered them to review, touching $ 4,750.00: ana.ap entered BILL/2026/10/0001 and paid it with PBNK1/2026/00003
Fail	Medium	Password length policy	No password policy module installed.
Fail	Medium	No free self sign-up	Anyone can create a portal account (free sign-up).
Fail	Medium	Custom modules restrict write access	1 access rule(s) from custom modules grant write/delete to every user, portal and public included (no group): lab.portal.note.
Fail	Medium	Dynamic templates restricted to administrators	1 non-administrator(s) can write dynamic email templates: ana.ap. Template expressions are evaluated on the server; the same class of bug gave remote code execution in other ERPs (e.g. CVE-2026-38431 in ERPNext).
Fail	Medium	Evidence seals kept outside Odoo	Assessment seals only live inside this database: an administrator could delete or rewrite the whole history. Set the system parameter shield.seal_recipients to an external mailbox (e.g. your auditor or board) to receive each seal.

Your logo

My Company
United States

Status	Severity	Control	Detail
Fail	Medium	Separate staging environment	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	Production change process	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	Incident response plan	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	No duplicate vendor bills	1 possible duplicate bill(s) to review, touching $ 4,750.00: BILL/2026/10/0002 duplicates BILL/2026/10/0001 (Northwind Logistics, $ 4,750.00)
Warning	Medium	Multi-process mode with limits	workers = 0: single process without memory/time limits; one heavy request can stall every user.
Warning	Medium	Third-party code free of risky patterns	1 risky pattern(s) in third-party code (0 high): HTML field without sanitizing (lab_vuln_portal/models.py:10)
Warning	Low	Database selection restricted	No dbfilter: any database on the server can be selected by URL.
Warning	Low	HTTPS everywhere	Base URL is local plain HTTP (http://localhost:8069); fine for testing only.
Warning	Low	Supported Odoo version	Odoo 18.0 is supported but 1 major version(s) behind 19.0.
Warning	Low	Third-party modules reviewed	1 third-party module(s) need security review and upgrade testing: lab_vuln_portal
Pass	Critical	Payments to new bank details are held	Payment hold enforced (30 days); 6 bank account(s) currently held for verification.
Pass	High	Limited Settings administrators	3 Settings administrator(s).
Pass	High	Developer mode off in production	Developer mode is off server-wide.
Pass	High	Odoo build patched	Build 18.0-20261015 is 15 days old; no known advisory applies.
Pass	Medium	No dormant internal accounts	No internal account idle for more than 90 days.
Pass	Medium	Segregation of duties in accounting	1 accounting administrator(s).
Pass	Medium	Scheduled actions healthy	No failing scheduled actions.

Status	Severity	Control	Detail
Pass	Medium	Module code and database in sync	All module code matches the database (47 modules).
Pass	Low	API keys owned and rotated	No API keys issued.
Pass	Low	Outgoing email delivered	No failed outgoing emails.
Not applicable	Medium	Outgoing mail uses TLS	No custom outgoing mail server configured.

Framework mappings support evidence collection and are not a certification. Scores reflect controls measured at the time of the assessment.

Evidence seal (SHA-256, chained to the previous assessment): feb45adbb0181528b777167bf50e98e0e996be94404302d381b89b07d1093dfd